SOLO WEB

หน้าเว็บเดียวของ Solo Empire สำหรับเจ้าของ: shell + thin BFF เรียก backend แยกราย module

NFR และความปลอดภัย

รหัสเอกสาร	SWB-DOC-03
ฉบับ	0.1
วันที่	2026-10-07
สถานะ	ร่างเพื่อพิจารณา

เอกสารภายในฉบับร่าง — ใช้ประกอบการพัฒนาและดูแลระบบ

สารบัญ

1. ตาราง NFR ที่วัดได้

2. Performance

3. Availability

4. Scalability

5. Security controls

6. Privacy / PDPA

7. Observability

8. Backup / DR

การอนุมัติ

แหล่งข้อมูล

03 — NFR และความปลอดภัย

1. ตาราง NFR ที่วัดได้

ID	หมวด	ข้อกำหนด	เป้าหมาย/ค่าที่วัดได้	หลักฐาน	สถานะ
NFR-01	Performance	timeout ของ proxy ต่อ backend	metadata 8 วินาที, Today 10, Cloud 15, Production 30; ไม่เกิน 30 วินาที	`lib/backends.ts`, test `bounds every backend request to at most 30 seconds`	สร้างแล้ว
NFR-02	Performance	Vercel function budget	`maxDuration: 60` สำหรับ `app/api/**/route.ts`	`vercel.json`	สร้างแล้ว
NFR-03	Performance	latency หน้า/ API บน hosted	**[ต้องยืนยัน]** ยังไม่มีเป้าหมาย P95 และ region API เป็น `us-west2`	`staging-targets.json`	ยังไม่กำหนด
NFR-04	Availability	uptime ต่อเดือน	**[ต้องยืนยัน]** ไม่มี SLA; APIs replica เดียว, `restartPolicyType=ON_FAILURE` max 3	`railway.toml`	ยังไม่กำหนด
NFR-05	Availability	module หนึ่งล่มไม่ทำให้ module อื่นล่ม	proxy ตอบ `503 backend_unavailable` เฉพาะ service นั้น	`route.ts`	สร้างแล้ว (hosted ยังไม่ทดสอบ)
NFR-06	Scalability	backend แยก origin ต่อ module	ทุก backend มี `*_ORIGIN` ของตนเอง	test `gives every module its own origin variable`	สร้างแล้ว
NFR-07	Security	อายุ session	≤3600 วินาที และ ≤ ID-token `exp`	`createOwnerSession`, test `limits session expiry to an hour`	สร้างแล้ว
NFR-08	Security	อายุ service JWT	`exp ≤ iat+120` และไม่เกิน session; API leeway 5 วินาที	`serviceAuthorization`, contracts `.v1`	สร้างแล้ว
NFR-09	Security	RSA signing key	PKCS8 RSA ≥2048 bits, RS256	`serviceSigningKey`, test `never reports ready ... below 2048 bits`	สร้างแล้ว
NFR-10	Security	anonymous access	anonymous read ผ่าน BFF และตรง API ได้ 401/403 เท่านั้น	`staging-smoke.mjs` (8 จาก 13 checks)	รอ hosted run
NFR-11	Privacy	ไม่คืนข้อมูลที่ระบุตัวตนแฝง/เนื้อหาเอกสาร	accounts คืน anonymous เป็น count เท่านั้น; knowledge ไม่คืน body	contracts accounts.v1 / knowledge.v1	สร้างแล้ว
NFR-12	Observability	health ไม่รั่วค่า	`/api/health` คืนชื่อ config + สถานะเท่านั้น	test `reports safe configuration-only health`	สร้างแล้ว
NFR-13	Usability	ภาษา	UI และข้อความ error เป็นภาษาไทย, `lang="th"`	`app/layout.tsx`, `lib/*`	สร้างแล้ว
NFR-14	Cost	ค่าโฮสติ้ง metadata phase แรก	กรอบวางแผน US$30–50/เดือน (ไม่ใช่ hard cap)	`staging-targets.json` `resource_approval`	อนุมัติแบบมีเงื่อนไข

2. Performance

- Proxy ใช้ `cache: 'no-store'` และ `AbortSignal.timeout(backend.timeoutMs)` ไม่มี cache ฝั่ง BFF
- AI Usage อ่านใหม่ทุก 60 วินาทีเมื่อหน้า visible (README)
- ยังไม่มีผล load test หรือการวัด latency บน hosted **[ต้องยืนยัน]**

3. Availability

- Frontend stateless; APIs เป็น read-only snapshot จึง restart ได้โดยไม่เสียข้อมูล
- Railway healthcheck ใช้ `/ready` (ตรวจทั้ง source และ auth) timeout 30 วินาที
- ไม่มี multi-region หรือ replica สำรองใน phase แรก

4. Scalability

- ย้าย/เพิ่ม replica ของ backend ได้โดยเปลี่ยน `*_ORIGIN` เท่านั้น (ADR-01)
- phase แรก: replica เดียว ไม่มี DB/disk/worker เพิ่มจนมี workload จริง (`staging-decision.md`)

5. Security controls

Control	รายละเอียด	แหล่ง
Authentication	OIDC authorization code + PKCE S256 + state + nonce; `enableNonRepudiationChecks`	`lib/auth.ts`
Authorization	allowlist `SOLO_WEB_OWNER_SUBJECTS` (JSON array ของ `sub`), `tenant_id=owner`	`lib/auth.ts`
Session	JWE `dir` / `A256GCM` , cookie `__Host-` + Secure + HttpOnly + SameSite=Lax + Path=/	`lib/auth.ts`
Host allowlist	Host ต้องตรงกับ `SOLO_WEB_PUBLIC_ORIGIN` หรือ `SOLO_WEB_PREVIEW_ORIGINS` (exact, ไม่มี wildcard); ไม่เชื่อ `X-Forwarded-Host`	`lib/request-guard.ts`
CSRF	mutation ต้องมี `Origin` ตรงทุกตัวอักษร + `Content-Type: application/json` ; logout ต้อง same-Origin POST	`guardRequest`
Credential isolation	ไม่ส่งต่อ `Authorization` , cookie, `X-Owner` ของผู้เรียก; BFF ออก service JWT ใหม่	proxy route, test `replaces caller credentials`
Backend origin	ไม่รับ credentials/path/query/fragment ใน origin; production ห้าม loopback; ไม่ตาม redirect (`redirect: 'error'`)	`lib/backends.ts`
Response hardening	`Cache-Control: no-store` , `X-Content-Type-Options: nosniff` , CSP `default-src 'none'` สำหรับ response ที่ไม่ใช่ JSON	proxy route
Secret handling	secret อยู่ใน server env/secret store เท่านั้น; preflight ปฏิเสธชื่อ `NEXT_PUBLIC_*` ของ secret	`staging-preflight.mjs`
Legacy token	`PRODUCTION_HUB_API_TOKEN` ใช้เฉพาะ local demo ไปยัง loopback	`lib/backends.ts`

ข้อจำกัดที่ทราบ:

- ไม่มี distributed session-revocation store หรือ IdP backchannel logout; cookie ที่ถูกขโมยใช้ได้จนหมดอายุ/หมุน key/ถอด subject
- logout ไม่เพิกถอน session ที่ IdP
- module accounts/integrations/saas/knowledge ยังมีฟอร์ม "กรอก access token" (เก็บในหน่วยความจำหน้า) จากโหมด local เดิม; ใน hosted mode proxy ไม่ส่งต่อค่านี้ **[ต้องยืนยัน]** ว่าจะคงหรือถอด UI นี้
- ไม่มี rate limiting ที่ BFF **[ต้องยืนยัน]** ว่าต้องมีหรือพึ่ง provider
- ยังไม่มี security headers ระดับหน้า (CSP/HSTS ของ page) ใน `next.config.ts` **[ต้องยืนยัน]**

6. Privacy / PDPA

- ผู้ใช้เดียวคือเจ้าของ; Solo Web ไม่เก็บข้อมูลส่วนบุคคลฝั่ง server นอกจาก `sub` ใน cookie ที่เข้ารหัส
- Metadata ที่ยังคงอยู่ใน build context (เช่นชื่อและเส้นทางเอกสาร) ยัง `publication_status: not_approved` ต้องผ่าน owner review ก่อนอัปโหลด
- Accounts ไม่คืน ID/purpose ของ anonymous identities
- การประเมิน PDPA อย่างเป็นทางการ **[ต้องยืนยัน]** — เป็นระบบส่วนตัว ไม่มีข้อมูลบุคคลที่สามโดยตรงตาม source แต่ account matrix อาจมีข้อมูลบัญชี

7. Observability

- `/api/health` (web) และ `/ready`, `/health` (APIs) เป็นสัญญาณเดียวที่มี
- ไม่มี structured logging, metrics, tracing หรือ alerting ใน `apps/solo-web` **[ต้องยืนยัน]** ว่าจะใช้ Vercel/Railway logs ในตัวหรือเพิ่มเครื่องมือ
- smoke script ไม่แสดง body, origins, keys หรือ exception text

8. Backup / DR

ส่วน	กลยุทธ์	สถานะ
Solo Web	redeploy revision ก่อนหน้า (stateless)	`rollback_revision` ยังว่าง
Metadata APIs	rebuild จาก exported context + checksum; source อยู่ใน Git	`snapshot_sha256` ยังว่าง
Session keys	หมุน `SOLO_WEB_SESSION_KEY` = เพิกถอนทุก session	เอกสารใน README
RTO/RPO	**[ต้องยืนยัน]** ยังไม่กำหนด	—

การอนุมัติ

บทบาท	สถานะ	วันที่	ลงนาม
Solution Architect	รอพิจารณา	—	___
Security	รอพิจารณา	—	___

แหล่งข้อมูล

- `apps/solo-web/lib/{auth.ts,request-guard.ts,backends.ts}`, `apps/solo-web/app/api/[service]/[...path]/route.ts`, `apps/solo-web/app/api/health/route.ts`
- `apps/solo-web/vercel.json`, `apps/solo-web/next.config.ts`, `apps/solo-web/README.md` (Proxy, Authentication)
- `apps/solo-web/tests/{auth,backends,api-proxy-route}.test.ts`
- `apps/solo-web/scripts/staging-preflight.mjs`, `apps/solo-web/scripts/staging-smoke.mjs`
- `services/*/contracts/*.v1.md`, `services/accounts-api/railway.toml`
- `apps/solo-web/deployment/staging-decision.md`, `apps/solo-web/deployment/staging-targets.json`